INSTRUCTOR SOLUTIONS

Using a Sandboxed Ticketing Website to Teach Digital Trust and IT Audit

These suggested answers cover both the standard student template, worksheet-version-1.docx, and the shorter alternative implementation student template, worksheet-version-2.docx. The shared sections below follow the worksheet headings. The COBIT framework questions and six-policy evaluation apply to Version 1 and may also be assigned as extensions to Version 2.

The examples are not exhaustive. Students may identify additional weaknesses or propose alternative controls. Strong answers should connect the observed system behavior to a specific control objective, explain why the weakness matters, and recommend a control that would prevent the issue or help management detect and review it. Instructors should confirm the results against the system version and evidence used in their classroom run. Ticket counts, balances, inventory, and timestamps depend on the classroom activity.

Shared Solutions for Both Worksheet Versions

Website Transaction Discovery

The event names and number of tickets purchased depend on the student's or group's activity. These responses should agree with the account's ticket holdings and the records supplied by the instructor. Suggested website observations are shown in Table 1. Version 2 lists the home, login, and user account pages; Version 1 also includes the cart page.

Table 1: Suggested Website Observations

Page Area	Suggested Observation
Home page	The homepage displays the SeatGate Trial event and a Find Tickets button that takes the user into the ticket-selection process.
Login page	A Sign In window asks for an assigned username and password. Users must authenticate before purchasing tickets.
User account page	The account page displays the logged-in user, wallet balance, number of tickets purchased, event details, quantities, amount paid, and purchase time.
Cart page	The cart displays the selected event, ticket quantity, price, wallet balance, order total, and balance after purchase. Before submitting, the user is also asked for class and date information.

Short Process Narrative

A user begins by: signing into SeatGate with an assigned account and selecting an available event.

The system then: displays available tickets and inventory, allows the user to select a quantity, places the selection in the cart, and shows the wallet balance and order total.

A ticket purchase is completed when: the authenticated purchase request is accepted by the backend, inventory and wallet requirements are satisfied, the transaction is recorded, inventory is updated, and a purchase record is generated. Students should distinguish a recorded purchase from one that satisfies all of management's stated control policies.

Controlled Automation Observation

What did the script attempt to do? The controlled demonstration authenticates the admin account, retrieves the available ticket type, and submits a purchase request for five tickets in one transaction. If the optional coding extension is used, a script may also submit repeated authenticated requests faster than a manual user. Students should describe the demonstration or script they actually observed.

Did the system block or limit the automated behavior? The sandbox permits the controlled admin purchase when funds and inventory permit it. The current repository also includes a configurable backend limit for student purchases and rate limiting. Students should compare the configured limit with the stated one-ticket-per-user-per-event policy and distinguish privileged admin purchases from student-account tests. Evidence should include the request result, the purchasing account's holdings, inventory changes, and any rate-limit audit entries. Students should not infer that all requests must succeed regardless of funds, inventory, or authentication.

Version 2 optional AI question: AI may generate or explain code for signing in, retrieving event and ticket information, and submitting purchase requests. The student still needs to understand the request, authentication, event and ticket identifiers, quantity, response, and effect on the records. Students should validate the output within the authorized SeatGate sandbox. An acceptable response is "not used" when the instructor did not assign this extension.

Internal-Control Review

Table 2 provides examples for both versions. In Version 1, students record the COBIT 2019 reference in its own column. In Version 2, they may include it with the description of the observed weakness. Students need not identify every example to demonstrate sound audit reasoning.

Table 2: Suggested Answer Key: Internal-Control Review

COBIT 2019 Reference / Optional Reference	Observed Control Failure	Recommendation	Control Type
DSS06.02 – Control the Processing of Information	If student accounts can buy more than one ticket, the configured limit does not match the stated one-ticket-per-user-per-event policy.	Configure backend validation to match the stated policy and check prior purchases for the same user and event before approving another purchase.	Preventive application control
DSS06.04 – Manage Errors and Exceptions	The system does not produce clear exception reports for rapid repeated or abnormal purchase requests.	Create exception reports for abnormal activity, such as repeated purchase attempts, failed transactions, unusually rapid requests, or other identified exceptions.	Detective control

COBIT 2019 Reference / Optional Reference	Observed Control Failure	Recommendation	Control Type
DSS05.07 – Manage Vulnerabilities and Monitor the Infrastructure for Security-Related Events *(NIST optional)*	Rate limiting may block some requests without establishing that all suspicious purchasing is identified or reviewed.	Review rate-limit audit entries and monitoring rules to determine whether repeated or abnormal requests are identified and reviewed.	Preventive and detective control
DSS06.02 – Control the Processing of Information	The configured backend limit may differ from management's stated one-ticket-per-event policy.	Enforce critical transaction rules on the backend, including authorization, purchase limits, inventory checks, and transaction validation.	Preventive application control
DSS05.04 – Manage User Identity and Logical Access	The `fakebuyer` account can access the system and purchase tickets even though it does not represent an authorized student user.	Require accounts to be approved and linked to authorized users. Periodically review user accounts and disable unauthorized or unnecessary accounts.	Preventive and detective access control
DSS06.02 – Control the Processing of Information **DSS06.05 – Ensure Traceability and Accountability for Information Events** *(financial-reporting consideration optional)*	Transactions generated by an unauthorized account may affect reported ticket sales or revenue and may make the reported amounts unreliable.	Validate the authorization and accuracy of transactions before they are included in management or financial reports, and retain transaction records that allow questionable amounts to be traced back to the originating user and transaction.	Preventive and detective control
DSS06.02 – Control the Processing of Information *(NIST optional)*	A direct API request is accepted despite violating a stated transaction policy. API discoverability alone is not a control failure.	Do not rely on the visible website interface as the primary control. Validate authorization, purchase limits, inventory, and transaction validity for every backend request.	Preventive application control
DSS05.07 – Manage Vulnerabilities and Monitor the Infrastructure for Security-Related Events *(NIST optional)*	The system has limited controls to prevent or detect automated repeated purchase requests.	Consider controls such as CAPTCHA, rate limiting, request throttling, or behavioral monitoring. Suspicious activity should also be logged and reviewed.	Preventive and detective control

Class Discussion and Debrief Questions

What was the most important internal-control weakness? A strong answer is the failure of the backend control to match management's stated policy. Management states that each student may purchase only one ticket per event, but repeated purchases or the controlled five-ticket request can exceed that limit. Students may select another significant weakness if they explain its risk and support it with evidence.

What evidence would an IT auditor need? The auditor can use an assigned test account to check each policy, document the request and response, and compare the result with ticket holdings, inventory changes, transaction logs, timestamps, and exception reports. The user population should be compared with the approved participant list. The fact that a transaction was recorded does not, by itself, show that it was properly authorized. Conclusions about revenue or other reported amounts should be supported by reconciliation to the underlying records rather than assumed from the presence of an unusual account.

Additional Solutions for the Standard Worksheet

COBIT 2019 Framework Questions

Table 3 provides suggested answers to the two framework questions.

Table 3: Suggested Answer Key: COBIT 2019 Framework

Question	Suggested Answer
Question 1	COBIT 2019 is a framework that helps organizations manage and oversee their use of technology. In the SeatGate case, an auditor can use COBIT to organize the review of areas such as user access, ticket purchases, system monitoring, and internal controls. It helps the auditor think about whether the system is being managed properly and whether its controls support the organization's goals.
Question 2	COBIT does not tell an organization exactly which technology or security solution to use. For example, it does not tell SeatGate exactly how to stop bots or which login control to install. COBIT helps identify what areas should be governed, managed, and controlled. More detailed cybersecurity guidance can come from frameworks and standards such as NIST, while management decides how to implement the specific controls.

Policy Evaluation

Table 4 gives the expected results for the six stated policies in the supplied sandbox. Instructors should accept a different conclusion when the student provides evidence from the classroom run that supports it.

Table 4: Suggested Answer Key: Policy Review

Policy	Status	Observed Weakness or Evidence
Policy #1	Check configuration	The repository enforces a configurable limit per ticket type, with a default of three for non-admin users. Compare the configured limit with the stated one-ticket-per-student-per-event policy and test it using a student account. A different limit or scope may cause the stated policy to fail; an admin purchase alone does not demonstrate this failure.
Policy #2	Not fully working	The `fakebuyer` account is able to purchase tickets even though it does not represent an authorized student user. The transaction may appear in the audit log, but logging the transaction does not prevent an unauthorized account from completing a purchase.
Policy #3	Working	Ticket inventory updates as expected after a successful purchase. The number of tickets sold increases and the remaining inventory decreases.
Policy #4	Evaluate reporting	The repository logs blocked requests, including `RATE_LIMIT_BLOCKED` events. Determine whether these events are included in an exception report and reviewed by management. Raw audit-log entries alone do not establish that the full policy is operating as intended.
Policy #5	Not fully working	The administrative ticket-holdings view does not display a timestamp for every individual ticket purchase. Transaction times may be available through the audit log, but the stated policy specifically requires the timestamp to appear in the admin view.
Policy #6	Not working	The system does not enforce a unique serial number for each individual ticket. Multiple tickets may be represented as part of the same purchase record or quantity, so individual tickets cannot be uniquely identified and traced.